REFLECTED XSS

PortSwigger Web Security Academy Lab Report

Prepared by: Sofia
Focus: Web Application Security / WAPT Foundations
Platform: PortSwigger Web Security Academy
Lab: Reflected XSS into HTML context with nothing encoded
IqraSec Academy - WAPT Internship - Phase 1

1. Executive Summary

The search function of this blog puts search term into the page without encoding. I injected a script that calls alert, which solved the lab.

2. Lab Information

Platform	PortSwigger Web Security Academy
Room / Lab	Reflected XSS into HTML context with nothing encoded
Primary Domain	Web Application Security
Purpose	Foundational WAPT practice
Completion	Completed - lab solved
Link	https://portswigger.net/web-security/cross-site-scripting/reflected/lab-html-context-nothing-encoded

3. Learning Objectives

- Understand reflected XSS.
- Find where input is reflected.
- Execute JavaScript with a simple payload.

4. Vulnerability / Concept

Cross-site scripting happens when an application returns user input in the page without encoding and the browser runs it as code. In reflected XSS the payload is in the request (here the search term) and comes straight back in the response.

5. Testing Approach

I searched for a normal word first to see where it is reflected: it appears inside the HTML with no encoding. Then I searched for **<script>alert(1)</script>**. The browser executed the script and an alert box appeared, so the lab was solved.

6. Evidence

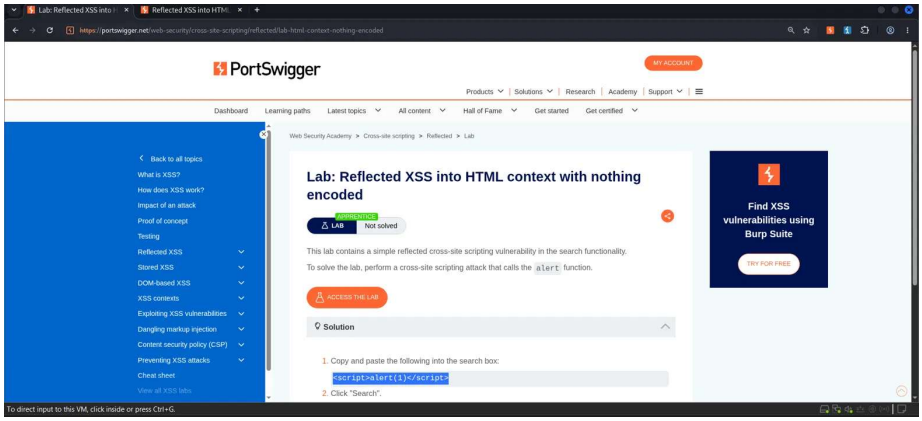


Fig 1 - Lab description.

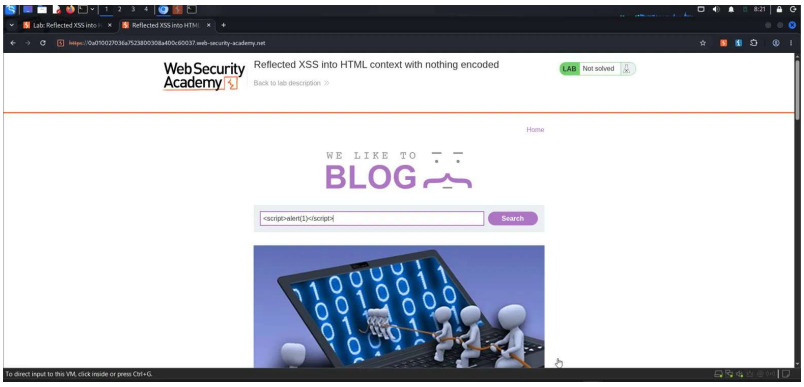


Fig 2 - Payload typed in the search box.

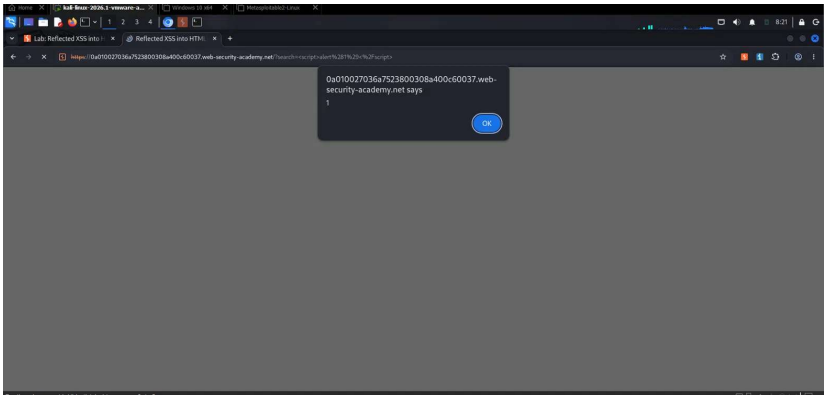


Fig 3 - Alert box shows the script ran.

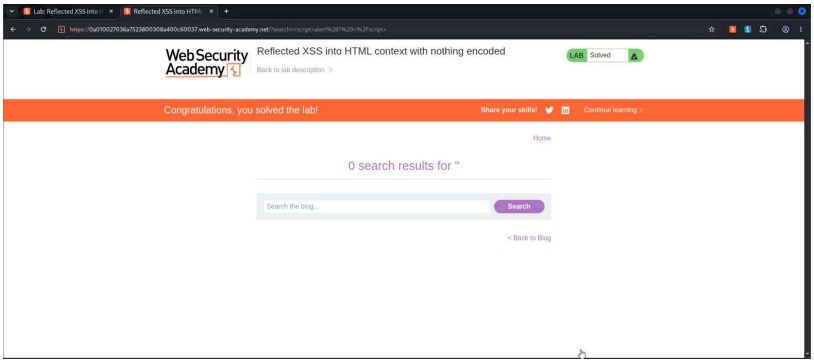


Fig 4 - Lab solved.

7. Impact

An attacker can send a crafted link to a victim and run JavaScript in the victim's session: steal cookies or tokens, act as the user, redirect to fake pages or change the page.

8. Remediation

- Encode output for the correct context (HTML, attribute, JavaScript).
- Validate input and use a strong Content-Security-Policy.
- Set HttpOnly on session cookies.

9. Key Security Takeaways

- Always check in which context the input is reflected.
- A simple alert payload is enough to prove the vulnerability.
- Output encoding is the main fix and CSP is a second layer.

10. Skills Practiced

Area	Practical understanding gained
XSS	Reflected XSS discovery and exploitation
Payloads	Script tag with alert
Analysis	Checking where input is reflected

11. What I Would Explore Next

I will try stored and DOM based XSS labs and learn how to bypass filters.

12. Conclusion

This lab showed me how one unencoded search box can allow code execution in the browser.
Completion status: Completed - lab solved.

13. References

PortSwigger Web Security Academy: https://portswigger.net/web-security/cross-site-scripting/reflected/lab-html-context-nothing-encoded